



# المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

3li.info

نسخة مجانية

# اقرأ الفصل الأول

هذه النسخة تضم الافتتاحية والمقدمة ودليل القراءة والفصل الأول كاملاً،  
والكتاب بفصوله التسعة عشر متاح الآن على أمازون.

اشترِ الكتاب من أمازون

[gulfcyber.3li.info](http://gulfcyber.3li.info)



# المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

2026



المرجع الخليجي الشامل في الأمن السيبراني

علي العنزي

الطبعة الأولى 2026

جميع الحقوق محفوظة للمؤلف، فلا يجوز نسخ أي جزء من هذا الكتاب أو تخزينه أو نقله بأي وسيلة دون إذن كتابي مسبق منه، ويستثنى من ذلك الاقتباس القصير في المراجعات والدراسات مع الإشارة إلى المصدر.

الرقم الدولي المعياري للكتاب ISBN 9798178685440، والنسخة الورقية منشورة نشرًا مستقلاً Independently published.

تصميم الغلاف والأشكال من عمل المؤلف.

موقع الكتاب والتدريبات المرافقة له على [gulfcyber.3li.info](http://gulfcyber.3li.info)

للتواصل مع المؤلف: [info@3li.info](mailto:info@3li.info)





# المحتويات

|       |                     |
|-------|---------------------|
| xxi   | افتتاحية            |
| xxiii | المقدمة             |
| xxv   | كيف تقرأ هذا الكتاب |
| xxvii | شكر وتقدير          |

## 1 الباب الأول: الأسس

|    |                                                      |   |
|----|------------------------------------------------------|---|
| 3  | مدخل إلى أمن المعلومات                               | 1 |
| 4  | 1.1 ما المعلومات ولماذا نحميها . . . . .             |   |
| 6  | 1.2 الخصائص الثلاث: السرية والسلامة والتوافر . .     |   |
| 9  | 1.3 أمن المعلومات والأمن السيبراني وحماية البيانات . |   |
| 9  | 1.4 المفردات الأربع: الأصل والتهديد والثغرة والخطر   |   |
| 10 | 1.5 مبادئ لا تتغير . . . . .                         |   |
| 11 | 1.6 أنواع الضوابط . . . . .                          |   |
| 13 | 1.7 لماذا تُخترق المؤسسات مع كل هذا . . . . .        |   |
| 13 | 1.8 الأمن عملية مستمرة لا منتج يُشترى . . . . .      |   |

|          |                                          |           |
|----------|------------------------------------------|-----------|
| <b>2</b> | <b>التحديات والمهاجمون</b>               | <b>19</b> |
| 2.1      | من يهاجمنا ولماذا                        | 20        |
| 2.2      | تشریح الهجوم                             | 21        |
| 2.3      | الهندسة الاجتماعية                       | 22        |
| 2.4      | البرمجيات الخبيثة                        | 23        |
| 2.5      | هجمات الشبكات والأنظمة                   | 25        |
| 2.6      | التهديد الداخلي                          | 26        |
| 2.7      | مشهد التهديدات في الخليج                 | 26        |
| 2.8      | كيف يفكر المدافع                         | 27        |
| <b>3</b> | <b>إدارة المخاطر</b>                     | <b>33</b> |
| 3.1      | لماذا نبدأ من الخطر لا من التقنية        | 34        |
| 3.2      | خطوات إدارة المخاطر                      | 35        |
| 3.3      | جرد الأصول وتصنيفها                      | 36        |
| 3.4      | تحديد التهديدات والثغرات                 | 37        |
| 3.5      | تحليل المخاطر بين النوعي والكمي          | 38        |
| 3.6      | معالجة المخاطر                           | 39        |
| 3.7      | شبهية المخاطر وتحملها                    | 40        |
| 3.8      | سجل المخاطر الحي                         | 40        |
| 3.9      | مخاطر الأطراف الثالثة وسلسلة التوريد     | 42        |
| 3.10     | المخاطر في سياقنا الخليجي                | 42        |
| <b>4</b> | <b>الحوكمة والسياسات والأطر والامثال</b> | <b>49</b> |
| 4.1      | ما الحوكمة ولماذا تفشل البرامج بدونها    | 50        |
| 4.2      | أين يقع أمن المعلومات في الهيكل          | 51        |
| 4.3      | هرم الوثائق                              | 52        |
| 4.4      | الأطر والمعايير الدولية                  | 53        |
| 4.5      | المشهد التنظيمي في الخليج                | 55        |

|     |                            |    |
|-----|----------------------------|----|
| 4.6 | الامثال ليس أمناً          | 58 |
| 4.7 | قياس البرنامج ورفع تقاريره | 59 |
| 4.8 | التأكيد والتدقيق           | 60 |

## 65 الباب الثاني: الضوابط التقنية

|      |                                          |    |
|------|------------------------------------------|----|
| 5    | التشفير                                  | 67 |
| 5.1  | ما يفعله التشفير وما لا يفعله            | 68 |
| 5.2  | التشفير المتماثل                         | 69 |
| 5.3  | التشفير غير المتماثل                     | 69 |
| 5.4  | دوال التجزئة ورموز المصادقة              | 70 |
| 5.5  | التوقيع الرقمي                           | 71 |
| 5.6  | البنية التحتية للمفاتيح العامة           | 71 |
| 5.7  | تأمين النقل بروتوكول TLS                 | 72 |
| 5.8  | كيف تختار الخوارزمية وطول المفتاح        | 73 |
| 5.9  | التشفير أثناء الاستخدام والحوسبة السرية  | 74 |
| 5.10 | أخطاء التطبيق التي تبطل أقوى الخوارزميات | 74 |
| 5.11 | إدارة المفاتيح ودورة حياتها              | 75 |
| 5.12 | التشفير في واقعنا                        | 76 |
| 5.13 | ما بعد الحوسبة الكمية                    | 76 |

## 83 الهوية والمصادقة وإدارة الصلاحيات 6

|     |                           |    |
|-----|---------------------------|----|
| 6.1 | المصطلحات الأربعة         | 84 |
| 6.2 | عوامل المصادقة            | 85 |
| 6.3 | كلمات المرور ما زالت معنا | 86 |
| 6.4 | الدخول الموحد والاتحاد    | 87 |
| 6.5 | نماذج التحكم في الوصول    | 87 |

|    |                                  |      |
|----|----------------------------------|------|
| 88 | إدارة الحسابات المميزة           | 6.6  |
| 88 | دورة حياة الهوية                 | 6.7  |
| 89 | الهويات غير البشرية              | 6.8  |
| 89 | حوكمة الهوية وإدارتها            | 6.9  |
| 90 | هوية العملاء                     | 6.10 |
| 91 | الدليل النشط وما حوله            | 6.11 |
| 91 | انعدام الثقة                     | 6.12 |
| 92 | الهوية الرقمية الوطنية في الخليج | 6.13 |

## 7 أمن الشبكات 99

|     |                                                   |      |
|-----|---------------------------------------------------|------|
| 100 | الشبكة من منظور المدافع                           | 7.1  |
| 101 | التجزئة والمناطق                                  | 7.2  |
| 102 | الجدران النارية بأجياها                           | 7.3  |
| 102 | كشف التسلل ومنعه                                  | 7.4  |
| 103 | الوصول عن بعد والشبكات الخاصة الافتراضية          | 7.5  |
| 104 | أمن نظام أسماء النطاقات                           | 7.6  |
| 104 | الشبكات اللاسلكية                                 | 7.7  |
| 105 | التحكم في الوصول إلى الشبكة والبروتوكولات القديمة | 7.8  |
| 105 | الحماية من حجب الخدمة                             | 7.9  |
| 106 | مراقبة حركة الشبكة                                | 7.10 |
| 106 | الفروع والعمل من أي مكان                          | 7.11 |
| 107 | الشبكة داخل مركز البيانات                         | 7.12 |
| 107 | مثال تطبيقي: تجزئة شبكة مؤسسة متوسطة              | 7.13 |
| 109 | الشبكة في المؤسسة الخليجية                        | 7.14 |

## 8 أمن الأنظمة ونقاط النهاية 115

|     |                          |     |
|-----|--------------------------|-----|
| 116 | التهيئة الآمنة والتحصين  | 8.1 |
| 117 | إدارة الثغرات والتحديثات | 8.2 |

|      |                                                           |     |
|------|-----------------------------------------------------------|-----|
| 8.3  | من مكافحة الفيروسات إلى كشف نقاط النهاية والاستجابة ..... | 118 |
| 8.4  | الامتياز على الجهاز .....                                 | 119 |
| 8.5  | الأجهزة المحمولة .....                                    | 120 |
| 8.6  | التشفير على الأجهزة والوسائط .....                        | 120 |
| 8.7  | التسجيل على مستوى النظام .....                            | 121 |
| 8.8  | الحوادم والبيئات الافتراضية .....                         | 121 |
| 8.9  | الأنظمة القديمة التي لا تموت .....                        | 122 |
| 8.10 | نقاط النهاية في المؤسسة الخليجية .....                    | 122 |

## 9 أمن التطبيقات والتطوير الآمن 129

|     |                                     |     |
|-----|-------------------------------------|-----|
| 9.1 | أشهر ثغرات التطبيقات .....          | 130 |
| 9.2 | دورة التطوير الآمنة .....           | 132 |
| 9.3 | نمذجة التهديدات للتطبيقات .....     | 133 |
| 9.4 | الاختبارات الأمنية للتطبيقات .....  | 133 |
| 9.5 | أمن واجهات البرمجة .....            | 134 |
| 9.6 | أمن سلسلة توريد البرمجيات .....     | 135 |
| 9.7 | الأمن في خط التسليم المستمر .....   | 135 |
| 9.8 | الحماية في زمن التشغيل .....        | 136 |
| 9.9 | التطبيقات في المؤسسة الخليجية ..... | 136 |

## 10 أمن الحوسبة السحابية 141

|      |                                          |     |
|------|------------------------------------------|-----|
| 10.1 | نماذج الخدمة والنشر .....                | 142 |
| 10.2 | المسؤولية المشتركة .....                 | 143 |
| 10.3 | الهوية في السحابة .....                  | 144 |
| 10.4 | الهيئة الخاطئة وإدارة الوضع الأمني ..... | 145 |
| 10.5 | الحاويات والخدمات المصغرة .....          | 145 |
| 10.6 | حماية البيانات في السحابة .....          | 146 |

|     |                                      |       |
|-----|--------------------------------------|-------|
| 146 | الشبكات السحابية                     | 10.7  |
| 147 | المراقبة والتسجيل في السحابة         | 10.8  |
| 147 | أمن البرمجيات كخدمة                  | 10.9  |
| 148 | الحكومة والامتثال والتوطين في الخليج | 10.10 |
| 148 | استراتيجية الخروج ومخاطر التركيز     | 10.11 |

## 11 أمن البيانات والخصوصية 155

|     |                                |      |
|-----|--------------------------------|------|
| 156 | التصنيف أساس كل شيء            | 11.1 |
| 158 | دورة حياة البيانات وضوابطها    | 11.2 |
| 159 | منع تسريب البيانات             | 11.3 |
| 159 | التشفير والإخفاء والترميز      | 11.4 |
| 160 | النسخ الاحتياطي والإتلاف الآمن | 11.5 |
| 161 | مبادئ الخصوصية                 | 11.6 |
| 162 | تقييم الأثر على الخصوصية       | 11.7 |
| 162 | خروقات البيانات والإبلاغ عنها  | 11.8 |
| 162 | البيانات في المؤسسة الخليجية   | 11.9 |

## 12 أمن الأنظمة الصناعية وإنترنت الأشياء 169

|     |                                       |       |
|-----|---------------------------------------|-------|
| 170 | عالم مختلف بأولويات معكوسة            | 12.1  |
| 171 | نموذج بيردو والمناطق والقنوات         | 12.2  |
| 172 | البروتوكولات الصناعية                 | 12.3  |
| 172 | التحديات على قطاعات المنطقة           | 12.4  |
| 173 | الضوابط الأساسية                      | 12.5  |
| 174 | دراسة حالة: محطة تحلية افتراضية       | 12.6  |
| 175 | المراقبة دون تعطيل                    | 12.7  |
| 175 | أمن إنترنت الأشياء                    | 12.8  |
| 176 | البنية التحتية الحيوية في الخليج      | 12.9  |
| 176 | الاستجابة للحوادث في البيئات الصناعية | 12.10 |

### 13 المعمارية الأمنية 183

|     |       |                                       |
|-----|-------|---------------------------------------|
| 184 | 13.1  | ما المعمارية الأمنية ولماذا           |
| 185 | 13.2  | الأطر المعمارية                       |
| 186 | 13.3  | المبادئ المعمارية                     |
| 187 | 13.4  | الأنماط المعمارية الآمنة              |
| 188 | 13.5  | معمارية انعدام الثقة                  |
| 189 | 13.6  | المعمارية السحابية ومنطقة الهبوط      |
| 190 | 13.7  | مراجعة المعمارية في المؤسسة           |
| 191 | 13.8  | قياس نضج المعمارية                    |
| 192 | 13.9  | المعمارية الأمنية في المؤسسة الخليجية |
| 192 | 13.10 | دراسة حالة: بنك يطلق تطبيق هاتف       |

### الباب الثالث: العمليات والصمود 199

#### 14 مراقبة الأمن والعمليات الأمنية 201

|     |       |                                   |
|-----|-------|-----------------------------------|
| 202 | 14.1  | الرؤية قبل الأدوات                |
| 203 | 14.2  | مركز العمليات الأمنية             |
| 203 | 14.3  | السجلات                           |
| 204 | 14.4  | إدارة المعلومات والأحداث الأمنية  |
| 204 | 14.5  | هندسة الكشف وحالات الاستخدام      |
| 205 | 14.6  | استخبارات التهديدات               |
| 205 | 14.7  | صيد التهديدات                     |
| 206 | 14.8  | الأتمتة والتنسيق                  |
| 206 | 14.9  | قياس أداء المركز                  |
| 207 | 14.10 | الاستعانة بمزود خارجي             |
| 207 | 14.11 | مركز العمليات في المؤسسة الخليجية |
| 208 | 14.12 | دراسة حالة: التنبيه الذي لم يُقرأ |

## 15 الاستجابة للحوادث والتحقيق الرقمي 213

|       |                                         |     |
|-------|-----------------------------------------|-----|
| 15.1  | الحدث والحادثة والحرق                   | 214 |
| 15.2  | دورة الاستجابة                          | 215 |
| 15.3  | الاستعداد                               | 216 |
| 15.4  | الساعة الأولى                           | 216 |
| 15.5  | الكشف والتحليل                          | 217 |
| 15.6  | الاحتواء والاستئصال والتعافي            | 217 |
| 15.7  | التواصل والإبلاغ التنظيمي               | 218 |
| 15.8  | التحقيق الرقمي                          | 218 |
| 15.9  | الدروس المستفادة                        | 219 |
| 15.10 | التمارين                                | 220 |
| 15.11 | دراسة حالة: برمجية فدية في مؤسسة متوسطة | 220 |

## 16 استمرارية الأعمال والتعافي من الكوارث 227

|       |                                     |     |
|-------|-------------------------------------|-----|
| 16.1  | المرونة التشغيلية بوصفها الهدف      | 228 |
| 16.2  | تحليل أثر الأعمال                   | 229 |
| 16.3  | استراتيجيات التعافي                 | 230 |
| 16.4  | السحابة والمرونة                    | 231 |
| 16.5  | النسخ الاحتياطي في مواجهة الفدية    | 231 |
| 16.6  | الخطط                               | 232 |
| 16.7  | التمارين والاختبارات                | 232 |
| 16.8  | اضطرابات ليست سيبرانية              | 233 |
| 16.9  | قائمة تحقق للاختبار السنوي          | 233 |
| 16.10 | الأطراف الثالثة والتركز             | 234 |
| 16.11 | المرونة التشغيلية في الأطر الخليجية | 234 |
| 16.12 | دراسة حالة: فقدان مركز بيانات       | 234 |

## 17 العنصر البشري والتوعية الأمنية 241

|       |                                                 |     |
|-------|-------------------------------------------------|-----|
| 17.1  | لماذا يفشل التدريب التقليدي . . . . .           | 242 |
| 17.2  | من التوعية إلى السلوك إلى الثقافة . . . . .     | 242 |
| 17.3  | بناء برنامج التوعية . . . . .                   | 243 |
| 17.4  | اختبارات التصيد المحاكاة . . . . .              | 244 |
| 17.5  | الرسالة التي تصل . . . . .                      | 244 |
| 17.6  | القيادة والقُدوة . . . . .                      | 245 |
| 17.7  | أمن الموظفين من التعيين إلى المغادرة . . . . .  | 245 |
| 17.8  | الهندسة الاجتماعية في البيئة الخليجية . . . . . | 245 |
| 17.9  | التوعية للعملاء والجمهور . . . . .              | 246 |
| 17.10 | التدريب بالمحاكاة والألعاب . . . . .            | 246 |
| 17.11 | الأمن في حياة الموظف الشخصية . . . . .          | 247 |
| 17.12 | دراسة حالة: حوالة مزورة . . . . .               | 247 |
| 17.13 | قياس البرنامج . . . . .                         | 248 |

## 253 الباب الرابع: آفاق

|      |                                                                  |     |
|------|------------------------------------------------------------------|-----|
| 18   | الذكاء الاصطناعي وأمن المعلومات                                  | 255 |
| 18.1 | الذكاء الاصطناعي في يد المهاجم . . . . .                         | 256 |
| 18.2 | الهجمات على نماذج اللغة الكبيرة والأنظمة المبنية عليها . . . . . | 257 |
| 18.3 | حوكمة استخدام الذكاء الاصطناعي في المؤسسة . . . . .              | 258 |
| 18.4 | النماذج المدربة داخلياً . . . . .                                | 258 |
| 18.5 | أسئلة قبل اعتماد أي أداة . . . . .                               | 259 |
| 18.6 | الذكاء الاصطناعي في الدفاع . . . . .                             | 259 |
| 18.7 | الأطر الناشئة . . . . .                                          | 260 |
| 18.8 | الاحتيال على الأفراد والعائلات . . . . .                         | 260 |
| 18.9 | دراسة حالة: المساعد الذي يقرأ البريد . . . . .                   | 261 |

|            |           |                                         |
|------------|-----------|-----------------------------------------|
| <b>267</b> | <b>19</b> | <b>المسيرة المهنية في أمن المعلومات</b> |
| 268        | 19.1      | خريطة التخصصات                          |
| 269        | 19.2      | المهارات التي تسبق كل شيء               |
| 270        | 19.3      | الشهادات بقيمتها الحقيقية               |
| 270        | 19.4      | بناء الخبرة قبل الوظيفة وبعدها          |
| 271        | 19.5      | مسارات نموذجية                          |
| 271        | 19.6      | السيرة الذاتية والمقابلة                |
| 272        | 19.7      | التعلم الذي لا يتوقف                    |
| 272        | 19.8      | سوق العمل الخليجي                       |
| 273        | 19.9      | دور الجامعات والجهات الحكومية           |
| 273        | 19.10     | أخلاقيات المهنة                         |
| 274        | 19.11     | الخطوة الشخصية                          |

## 281 الملاحق

|            |                                             |
|------------|---------------------------------------------|
| <b>281</b> | <b>قائمة تحقق للمؤسسة الصغيرة والمتوسطة</b> |
| 281        | الهوية والحسابات                            |
| 282        | الأجهزة والأنظمة                            |
| 282        | الشبكة والوصول                              |
| 282        | البيانات والنسخ الاحتياطي                   |
| 283        | الأفراد                                     |
| 283        | الاستعداد والامثال                          |

## 285 مسرد المصطلحات

|            |                          |
|------------|--------------------------|
| <b>299</b> | <b>المراجع والمصادر</b>  |
| 299        | الأطر والمعايير الدولية  |
| 300        | الأطر والقوانين الخليجية |

302 ..... أبحاث المؤلف

303 ..... الأدلة الفنية والتقارير

**305** **عن المؤلف**





## قائمة الأشكال

|      |                                                 |     |
|------|-------------------------------------------------|-----|
| 1.1  | ثالث السرية والسلامة والتوافر . . . . .         | 6   |
| 2.1  | مراحل سلسلة القتل السيبرانية السبع . . . . .    | 21  |
| 3.1  | دورة إدارة المخاطر . . . . .                    | 35  |
| 4.1  | هرم الوثائق من السياسات إلى الإرشادات . . . . . | 52  |
| 5.1  | سلسلة الثقة في الشهادات الرقمية . . . . .       | 71  |
| 6.1  | العمليات الأربع لإدارة الهوية والوصول . . . . . | 84  |
| 7.1  | مناطق الشبكة من الأقل ثقة إلى الأعلى حساسية     | 101 |
| 8.1  | دورة إدارة الثغرات . . . . .                    | 117 |
| 9.1  | الأمن في كل مرحلة من دورة التطوير . . . . .     | 132 |
| 10.1 | توزيع المسؤولية بين المزود والعميل . . . . .    | 143 |
| 11.1 | دورة حياة البيانات . . . . .                    | 158 |
| 12.1 | مستويات نموذج بيردو والمنطقة الوسيطة . . . . .  | 171 |

|     |                                                  |      |
|-----|--------------------------------------------------|------|
| 186 | طبقات المعمارية الأمنية من الأعمال إلى التشغيل   | 13.1 |
| 188 | معمارية مرجعية لمؤسسة مالية بمناطقها ومكوناتها   | 13.2 |
| 189 | أركان معمارية انعدام الثقة ونقاط القرار والإنفاذ | 13.3 |
| 190 | منطقة الهبوط السحابية . . . . .                  | 13.4 |
| 191 | مراحل مراجعة المعمارية من الاستقبال إلى التحقق   | 13.5 |
| 202 | مسار المراقبة من المصدر إلى الاستجابة . . . . .  | 14.1 |
| 215 | دورة الاستجابة للحوادث . . . . .                 | 15.1 |
| 229 | دورة بناء المرونة التشغيلية . . . . .            | 16.1 |
| 243 | من التوعية إلى الثقافة . . . . .                 | 17.1 |
| 257 | ما يدخل إلى النموذج وما يخرج منه . . . . .       | 18.1 |
| 269 | عائلات التخصص في أمن المعلومات . . . . .         | 19.1 |



## قائمة الجداول

|      |                                           |     |
|------|-------------------------------------------|-----|
| 1.1  | الخصائص الثلاث وما يحفظها                 | 8   |
| 1.2  | وظائف الضوابط الخمس                       | 12  |
| 3.1  | دورة إدارة المخاطر                        | 36  |
| 3.2  | الحقول الأساسية في سجل المخاطر            | 41  |
| 4.1  | أشهر الأطر والمعايير وما يناسب كلاً منها  | 54  |
| 5.1  | الخيارات التفسيرية المعتمدة لأشيع الحاجات | 73  |
| 6.1  | عوامل المصادقة الشائعة ومقاومتها للتصيد   | 86  |
| 7.1  | تقسيم نموذجي لشبكة مؤسسة متوسطة           | 108 |
| 9.1  | أشهر فئات ثغرات التطبيقات وضوابطها        | 131 |
| 10.1 | توزيع المسؤولية بحسب نموذج الخدمة         | 144 |
| 11.1 | مثال لمخطط تصنيف من أربعة مستويات         | 157 |
| 16.1 | مثال على مخرجات تحليل أثر الأعمال         | 230 |





## افتتاحية

كان الغيص في خليجنا ينزل إلى القاع وحياته معلقة بجبل يمسكه السيب<sup>1</sup> فوق السطح، فإذا شد الغيص الحبل رُفِع، وإذا أُرْخِيَ له غطس واثقاً بمن يشد له الحبل ويرخيه، وهكذا كانت حياتنا في بلاد الخليج العربي كلها معلقة بجبال كهذه، بثقة بين من يشد ومن يرخي، وبما توارثته الأجيال من ثقافتنا البحرية والبرية.

واليوم تتدلى حياتنا من جبال أخرى لا تُرى، أسلاك في قاع البحر وموجات في الهواء وشفرة في أجهزة لا تعرف الولاء، تمر عليها روايتنا وسجلتنا الصحية وهوياتنا وأسرار شركائنا، ويدار بها الماء الذي نشربه والكهرباء التي تبرد بيوتنا والمال الذي نتعامل به، وصار الذي يمسك هذه الجبال ويحرسها هو من نسميه اليوم المختص في أمن المعلومات، وما هو بأقل ممن كان يشد الحبل ويرخيه ثقةً ولا مسؤولية.

كُتِبَ هذا الكتاب لهؤلاء ولمن يريد أن يكون منهم، وكُتِبَ من داخل الميدان لا من بعيد، من غرف العمليات والمراجعات والحوادث والاجتماعات مع الجهات المنظمة، وكُتِبَ جواباً عن سؤال سمعته سنوات

---

<sup>1</sup> الغيص هو الغواص الذي ينزل إلى قاع البحر ليجمع المحار في موسم الغوص على اللؤلؤ، والسيب هو البحار الذي يمسك حبله فوق سطح الماء ويسحبه إلى الأعلى حين يشد الحبل

من الطالب والمهندس والمدير على السواء عن مرجع عربي يجمع المجال كله بلغتنا وأطرنا وأمثلتنا، فلم يكن موجوداً فكان لا بد أن يكتب.

ولم أرد كتاباً يترجم ما كُتب في بلاد أخرى ثم يلحق به فصلاً عن الخليج، بل كتاباً يبدأ من هنا، تُذكر فيه أطر مصارفنا المركزية وهيئاتنا الوطنية وقوانين بياناتنا في موضعها من كل فصل، وتُروى فيه حوادث منطقتنا وأخطاء مؤسساتنا وما ينجح فيها حقاً، وتجدر فيه الجامعات والجهات الحكومية مادة تبني عليها، وتُنشر تدريباته وأشكاله وأدواته مفتوحة ليبنى عليها غيري.

ولا يدعي الكتاب أنه الكلمة الأخيرة في مجال يتبدل كل عام، بل هو كلمة أولى أردتها متينة بما يكفي ليبنى عليها، فإن وجدت فيه ما ينفع فأنشره، وإن وجدت فيه خطأً فراسلني، وإن علمته غيرك فقد أمسكت الحبل لمن بعدك.

علي العنزي، الكويت، 2026.



## المقدمة

لم أجد في بداية طريقي المرجع العربي الذي كنت أتمنى أن أقرأه، فالمراجع الأجنبية غزيرة لكنها تخاطب واقعاً غير واقعنا، أنظمة لا نخضع لها وأمثلة لا نعيشها ومصطلحاً لا يعرفه زملاؤنا، والمحتوى العربي متناثر بين ترجمات حرفية ومقالات متفرقة لا يجمعها خيط واحد، فكان على من يتعلم المجال في منطقتنا أن يجمعه بنفسه من عشرات المصادر، وهذا الكتاب محاولة لأن يجده من يأتي بعدي مجموعاً.

يخاطب الكتاب ثلاث فئات من القراء، فهو مدخل منظم لطالب الجامعة والمبتدئ الذي يريد أن يفهم المجال من جذوره، ومرجع عملي للمهندس والحلل الذي يعمل في الميدان ويحتاج إلى تثبيت المفاهيم وربطها بعضها ببعض، وخريطة واضحة للمدير والقيادي والمسؤول الحكومي الذي يتخذ قرارات تمس أمن مؤسسته دون أن يكون متخصصاً في التفاصيل التقنية، وقد كُتب ليكون مرجعاً تعتمد عليه الجامعات في مقرراتها والجهات الحكومية في برامج التأهيل، ويشرح دليل القراءة في الصفحات التالية كيف يستفيد منه كل قارئ بحسب حاجته.

قسمت الكتاب إلى أربعة أبواب، فيضع الباب الأول الأسس من مفاهيم وتهديدات ومخاطر وحوكمة، ويتناول الباب الثاني الضوابط التقنية من التشفير إلى الأنظمة الصناعية ويختتمها بفصل المعمارية الأمنية الذي يجمعها في تصميم واحد، ويعالج الباب الثالث العمليات والصمود من المراقبة

إلى الاستجابة والتعافي والعنصر البشري، ويطل الباب الرابع على الآفاق في الذكاء الاصطناعي والمسيرة المهنية، وتختتم الملاحق الكتاب بقائمة تحقق للمؤسسة الصغيرة والمتوسطة ومسرد شامل ومراجع.

وفي الختام فإن هذا الكتاب جهد بشري قابل للخطأ والتحسين، فإن وجدت فيه خطأ أو كان لديك اقتراح فراسلني على [info@3li.info](mailto:info@3li.info) وسأكون ممتناً لك، وأسأل الله أن ينفع به كل من قرأه.



## كيف تقرأ هذا الكتاب

يختلف القراء فيما يحتاجون إليه من هذا الكتاب، ولذلك رُسمت أربعة مسارات للقراءة، فالطالب والمبتدئ يقرآن الأبواب بترتيبها لأن كل فصل يبني على ما قبله ويحيل إليه، والممارس يبدأ من الفصل الذي يحتاج إليه مباشرة ويرجع إلى الباب الأول حين يصادف مفهوماً يحتاج إلى تثبيت، والقيادي والمسؤول الحكومي يقرآن الباب الأول كاملاً ثم الفصل الثالث عشر عن المعمارية والباب الثالث عن العمليات والصمود لأنها الفصول التي تمس قراراتهما، والمدرّب والأستاذ الجامعي يبنيان المقرر على أهداف التعلم في أول كل فصل والتمارين في آخره ويجدان التدريبات والقوالب والأشكال في المستودع المرافق.

وتتبع فصول الكتاب بنية واحدة، فيبدأ كل فصل بصندوق أهداف التعلم ثم مقدمة تربط الموضوع بالواقع، ثم الأقسام وفيها شكل توضيحي واحد على الأقل وأمثلة ودراسة حالة في كثير منها، ثم أخطاء شائعة تتكرر في مؤسسات المنطقة، ثم قائمة تحقق يقيس بها القارئ مؤسسته، ثم خلاصة الفصل، ثم جدول المصطلحات بالعربية والإنجليزية، ثم خريطة إلى الأطر الدولية والخليجية التي يقابلها الفصل، ثم أسئلة للمراجعة، ثم تمارين تطبيقية، ثم مصادر للتعمق.

وأتبعت في الكتاب مواضع ثابتة، فالمصطلح الإنجليزي يُذكر بين قوسين عند أول ورود له في كل فصل ويُجمع المسرد في آخر الكتاب، والأعداد بالأرقام العربية، وأسماء الأطر والمعايير بأسمائها الرسمية مع رموزها الدولية، والأمثلة لا تذكر مؤسسات بعينها إلا ما صار حدثاً عاماً موثقاً، وحين يُذكر إطار خليجي فالمقصود إصداره النافذ وقت الكتابة، ويحسن الرجوع إلى الجهة المصدرة لمعرفة أحدث إصدار، وتجدر التدريبات والقوالب والأشكال والأدوات في موقع الكتاب [gulfcyber.3li.info](http://gulfcyber.3li.info) وفي مستودعه المفتوح، وفي الموقع نفسه قناة لإبلاغ الأخطاء واقتراح التحسينات.



## شكر وتقدير

---

لم يكتب هذا الكتاب في عزلة، فكل فكرة فيه مرت بنقاش مع زميل أو اختبار في ميدان أو سؤال من طالب، فالشكر لزملائي في القطاع المالي الخليجي الذين تعلمت منهم أن الأمن قرار قبل أن يكون أداة، ولأعضاء لجان الأمن السيبراني القطاعية الذين يثبتون كل أسبوع أن المؤسسات تحمي بعضها بعضاً حين تتشارك، وللجهات المنظمة في دول المجلس التي حولت الأمن من توصية إلى إطار، ولطلائي ومتدربي الذين كانت أسئلتهم أصدق مراجعة لكل فصل، وللمجتمع المصادر المفتوحة الذي بُنيت بأدواته تدريبات هذا الكتاب وأشكاله وغلافه، ولأسرتي التي تحملت ساعات الكتابة الطويلة وكانت أول من قرأ، فما فيه من صواب فبفضلهم جميعاً وما فيه من خطأ فعليّ وحدي.

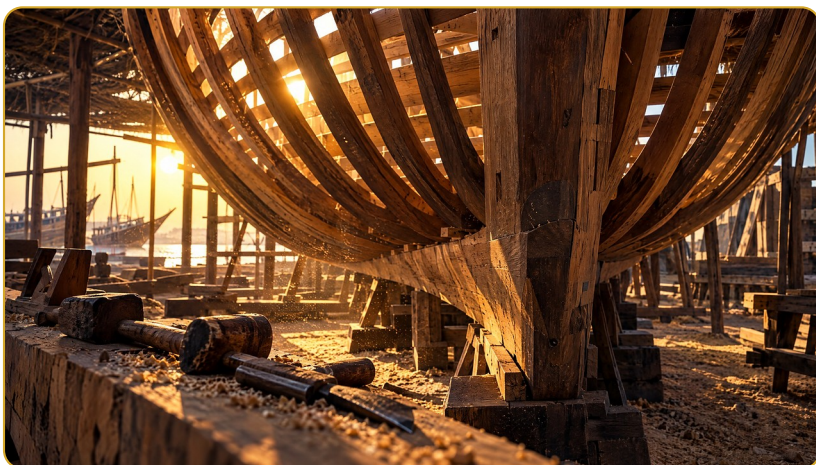




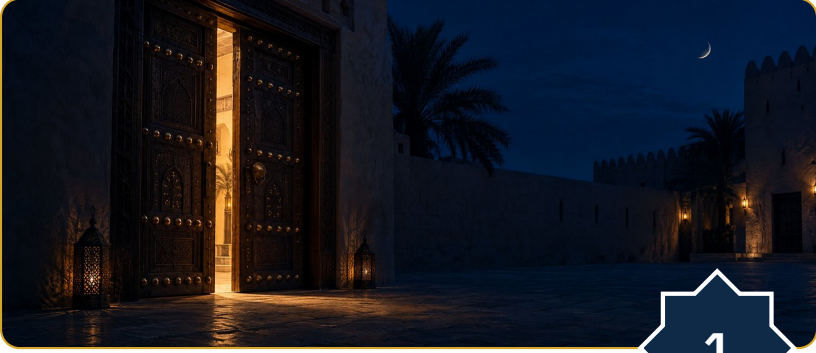
الباب الأول

# الأسس

---







## الفصل الأول

# مدخل إلى أمن المعلومات

### ♦ في هذا الفصل

|     |                                          |   |     |                                   |
|-----|------------------------------------------|---|-----|-----------------------------------|
| 1.1 | ما المعلومات ولماذا نحميها               | 4 | 1.4 | المفردات الأربع: الأصل والتهديد   |
| 1.2 | الخصائص الثلاث: السرية والسلامة والتوافر | 6 | 1.5 | الثغرة والخطر                     |
| 1.3 | أمن المعلومات والأمن السبراني            | 9 | 1.6 | مبادئ لا تتغير                    |
|     | وحماية البيانات                          |   | 1.7 | أنواع الضوابط                     |
|     |                                          |   | 1.8 | لماذا تُخترق المؤسسات مع كل هذا   |
|     |                                          |   |     | الأمن عملية مستمرة لا منتج يُشترى |

### 🎯 أهداف التعلم

بعد دراسة هذا الفصل ستكون قادراً على:

- تعريف المعلومات وتمييزها عن البيانات والمعرفة وبيان سبب حمايتها
- شرح خصائص السرية والسلامة والتوافر والخصائص المكملة لها بأمثلة
- التمييز بين أمن المعلومات والأمن السبراني وحماية البيانات
- استخدام مفردات الأصل والتهديد والثغرة والخطر والضوابط استخداماً صحيحاً
- تصنيف الضوابط بحسب طبيعتها ووظيفتها وشرح المبادئ الثابتة للحماية

في صباح يوم عمل عادي يصل مدير العمليات في شركة متوسطة إلى مكتبه فيجد شاشات الموظفين كلها تعرض رسالة واحدة تخبره بأن ملفات

الشركة شُفرت وأن استعادتها تتطلب دفع مبلغ بعملة رقمية في غضون ثلاثة أيام، فتتوقف الفواتير والرواتب والعقود دفعة واحدة، ويكتشف الجميع في تلك اللحظة أن الشركة لم تكن تبيع منتجات فحسب بل كانت تقوم على معلومات لم يفكر أحد في حمايتها جدياً.

تتكرر هذه القصة كل يوم بأشكال مختلفة في المستشفيات والجامعات والجهات الحكومية والبنوك والمتاجر الصغيرة، وما يجمع بين ضحاياها ليس ضعف التقنية وحده بل غياب الفهم المنظم لما ينبغي حمايته ومن يهدده وكيف تُبنى الحماية، ولذلك يبدأ هذا الكتاب من الأساس، أي من تعريف المعلومات وخصائصها التي نحميها والمفردات التي يتحدث بها المختصون والمبادئ التي لا تتغير مهما تغيرت التقنية.

## 1.1 ما المعلومات ولماذا نحميها

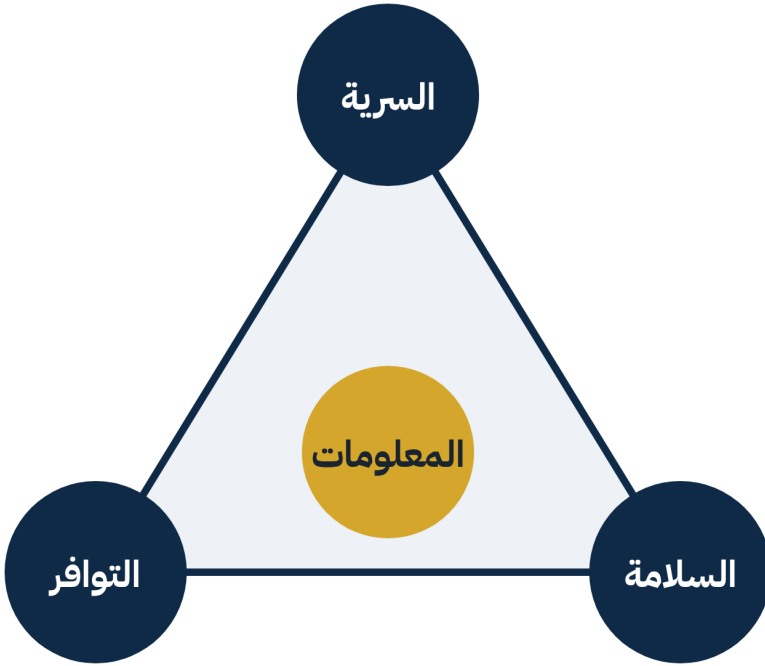
تبدأ الحكاية بالبيانات (Data) وهي حقائق خام لا معنى لها في ذاتها كرقم هاتف منفرد أو تاريخ أو مبلغ، فإذا رُتبت هذه البيانات في سياق صارت معلومات (Information) كأن نعرف أن هذا الرقم يخص عميلاً بعينه وأن ذلك المبلغ هو رصيده في تاريخ محدد، وإذا تراكمت المعلومات وفُسرت صارت معرفة (Knowledge) تُبنى عليها القرارات، ونحن نحكي المعلومات لأن لها قيمة، فقيمتها قد تكون مالية كبيانات البطاقات المصرفية، أو قانونية كالعقود والسجلات الطبية، أو تنافسية تخطط المنتجات وأسعار العطاءات، أو إنسانية كصور العائلة وأسرار المرضى، وقد تكون قيمتها في مجرد توافرها في اللحظة المناسبة كبيانات المريض على طاولة العمليات.

ولا تعيش المعلومات في الحاسوب وحده، فهي في الورق المطبوع وفي الأحاديث الجانبية وفي ذاكرة الموظفين وفي الرسائل النصية وفي الصور الملتقطة بالهاتف، ولهذا يتحدث المختصون عن حالات المعلومات

1

الثلاث، أي المعلومات أثناء التخزين (At Rest) على الأقراص والنسخ الاحتياطية، وأثناء النقل (In Transit) عبر الشبكات والبريد، وأثناء الاستخدام (In Use) في ذاكرة التطبيقات وعلى الشاشات، فالحماية التي تغطي حالة واحدة وتهمل الآخرين تشبه باباً محصناً في بيت بلا جدران. وتتم المعلومات بدورة حياة تبدأ بالإنشاء ثم التخزين ثم الاستخدام والمشاركة ثم الأرشفة ثم الإتلاف، ويحتاج كل طور من هذه الأطوار إلى حماية تناسبه، فالمعلومة التي أُتلفت بطريقة غير صحيحة قد تعود إلى الظهور من قرص بيع في سوق المستعمل، والمعلومة التي سُلمت إلى طرف ثالث خرجت من نطاق سيطرتك ما لم تُضبط مشاركتها بعقد وضوابط.

## 1.2 الخصائص الثلاث: السرية والسلامة والتوافر



شكل 1.1 ثالوث السرية والسلامة والتوافر

يتفق المختصون على أن حماية المعلومات تعني الحفاظ على ثلاث خصائص أساسية يُعرف مجموعها بـثالوث السرية والسلامة والتوافر (CIA Triad)، وكل خاصية منها تجيب عن سؤال مختلف، فالسرية (Confidentiality) تجيب عن سؤال من يحق له أن يرى هذه المعلومة، والسلامة (Integrity) تجيب عن سؤال هل هذه المعلومة صحيحة ولم تُغيّر دون إذن، والتوافر (Availability) يجيب عن سؤال هل المعلومة موجودة حين نحتاج إليها.

وتنتهك السرية حين يُطلع على المعلومة من لا يحق له ذلك، سواء أكان السبب مهاجماً سرق قاعدة بيانات العملاء أم موظفاً فضولياً فتح ملف زميله الطبي أم جهازاً ضاع في سيارة أجرة وفيه نسخة غير مشفرة من العقود، وتشمل أدوات حفظ السرية التشفير وضبط الصلاحيات وتصنيف المعلومات والتدريب على عدم إفشاءها.

وتُنتهك السلامة حين تُغيّر المعلومة أو تُحذف أو تُختلق دون صلاحية، كأن يعدّل موظف رصيذاً في النظام أو يغيّر مهاجم رقم الحساب في فاتورة مرسلة بالبريد لتذهب الحوالة إلى حسابه هو، وقد تنتهك السلامة دون نية خبيثة نكطاً في البرمجة يفسد السجلات أو عطل في القرص، وتشمل أدوات حفظ السلامة دوال التجزئة (Hash Functions) والتوقيع الرقمي وسجلات التدقيق والفصل بين المهام وضوابط التحقق من المدخلات.

ويُنتهك التوافر حين تصبح المعلومة أو الخدمة غير متاحة في الوقت الذي يحتاج إليها فيه أصحابها، كهجوم حجب الخدمة الذي يعطل بوابة حكومية في موسم تقديم الطلبات أو برمجية فدية تغلق نظام مستشفى أو انقطاع الكهرباء في ذروة الصيف عن مركز بيانات بلا مولد احتياطي، وتشمل أدوات حفظ التوافر التكرار (Redundancy) والنسخ الاحتياطي وخطط الاستمرارية والحماية من حجب الخدمة.

ولا يعني الثالث أن الخصائص الثلاث متساوية الأهمية في كل سياق، فالسرية هي الأولوية القصوى في بيانات الاستخبارات، بينما يتقدم التوافر في أنظمة التحكم الصناعي التي يعني توقفها خطراً على الأرواح، وتتقدم السلامة في الأنظمة المالية التي يهدد التلاعب بها الثقة كلها، ولهذا تبدأ أي حماية جادة بسؤال بسيط عن الخاصية التي يضر فقدانها أكثر من غيرها في هذا النظام تحديداً.

وقد أضاف المختصون إلى الثالث خصائص مكملة يرد ذكرها كثيراً في المعايير والعقود، وهي الأصالة (Authenticity) أي التأكد من أن المعلومة صادرة عن يدعي إصدارها، وعدم الإنكار (Non-repudiation) أي عجز الطرف عن إنكار فعل صدر عنه كتوقيع عقد أو إرسال أمر تحويل، والمساءلة (Accountability) أي إمكانية نسبة كل فعل في النظام إلى شخص محدد، والخصوصية (Privacy) أي حق الأفراد في التحكم في معلوماتهم الشخصية، وهو ما أصبح له في دول الخليج أنظمة وقوانين خاصة سنفصلها في فصل أمن البيانات.

### جدول 1.1 الخصائص الثلاث وما يحفظها

| الخاصية | السؤال الذي تجيب عنه         | مثال على انتهاكها               | ضوابط نموذجية                             |
|---------|------------------------------|---------------------------------|-------------------------------------------|
| السرية  | من يحق له الاطلاع            | تسريب قاعدة بيانات العملاء      | التشفير وضبط الصلاحيات والتصنيف           |
| السلامة | هل المعلومة صحيحة وغير معدلة | تغيير رقم حساب في فاتورة        | التجزئة والتوقيع الرقمي وسجلات التدقيق    |
| التوافر | هل المعلومة متاحة وقت الحاجة | تعطل بوابة خدمات في موسم الذروة | التكرار والنسخ الاحتياطي وخطط الاستمرارية |

### 1.3 أمن المعلومات والأمن السيبراني وحماية البيانات

تداخل هذه المصطلحات الثلاثة في الاستخدام اليومي حتى يظنها كثيرون شيئاً واحداً، غير أن لكل منها نطاقاً مختلفاً، فأمن المعلومات (Information Security) هو المظلة الأوسع لأنه يُعنى بحماية المعلومات سواء أكانت رقمية أم ورقية أم شفوية، أما الأمن السيبراني (Cybersecurity) فيركز على حماية الأنظمة الرقمية والشبكات والبيانات التي تمر عبرها من الهجمات الإلكترونية، فهو جزء من أمن المعلومات وإن كان الجزء الأكبر والأكثر حضوراً في عصرنا، وأما حماية البيانات (Data Protection) فتتطرق إلى المسألة من زاوية الحقوق والقانون، أي حق الفرد في أن تُجمع بياناته الشخصية وتُعالج وتُحفظ وفق قواعد واضحة تحترم خصوصيته.

ويساعد التمييز بين النطاقات الثلاثة على تحديد المسؤوليات داخل المؤسسة، فحماية الوثيقة الورقية في الأرشيف من الحريق والسرقة مسؤولية أمن المعلومات ولا علاقة لها بالشبكة، وصدد هجوم على الموقع الإلكتروني عمل سيبراني بحت، وسؤال هل يحق لنا الاحتفاظ ببيانات هذا العميل بعد انتهاء تعامله معنا شأن من شؤون حماية البيانات يجيب عنه القانون والسياسة قبل التقنية، وفي الممارسة العملية تلتقي النطاقات الثلاثة في برنامج واحد يقوده الرئيس التنفيذي لأمن المعلومات (CISO) بالتعاون مع مسؤول حماية البيانات والمختصين القانونيين.

### 1.4 المفردات الأربع: الأصل والتهديد والثغرة والخطر

يتحدث المختصون بلغة تقوم على أربعة مصطلحات لا بد من إتقانها قبل أي شيء آخر، فالأصل (Asset) هو كل ما له قيمة للمؤسسة ويحتاج إلى حماية، وقد يكون معلومة كقاعدة بيانات أو نظاماً تكاد أو خدمة كالبوابة

الإلكترونية أو إنساناً كموظف يحمل معرفة لا يملكها غيره أو سمعة يصعب استعادتها، والتهديد (Threat) هو أي حدث أو فاعل يمكن أن يلحق الضرر بالأصل سواء أكان مهاجماً أم موظفاً مهملاً أم حريقاً أم عطلاً، والثغرة (Vulnerability) هي نقطة الضعف في الأصل أو في حمايته التي تتيح للتهديد أن يحقق ضرره كبرجية لم تُحدث أو كلمة مرور ضعيفة أو منفذ خادم مفتوح، والخطر (Risk) هو احتمال أن يستغل تهديد ثغرة في أصل مضرراً في حجم الأثر الناتج عن ذلك.

ويمكن تلخيص العلاقة بينها في معادلة بسيطة تقول إن الخطر هو حاصل اجتماع التهديد والثغرة والأثر، فإذا غاب أحد الثلاثة غاب الخطر، فالثغرة في نظام لا يهدده أحد ليست خطراً حقيقياً، والتهديد الذي لا يجد ثغرة يستغلها يبقى تهديداً نظرياً، والاستغلال الذي لا يترتب عليه أثر لا يستحق الموارد، وعلى هذه المعادلة يقوم علم إدارة المخاطر كله الذي نفصله في الفصل الثالث.

ويرتبط بهذه المفردات مصطلح الضابط (Control) وهو الإجراء الذي نتخذه لتقليل الخطر إما بإزالة الثغرة وإما بالحد من التهديد وإما بتخفيف الأثر، ومصطلح الخطر المتبقي (Residual Risk) وهو ما يبقى من الخطر بعد تطبيق الضوابط، لأن الخطر لا ينعدم أبداً مهما أنفقنا، وإنما نخفضه إلى مستوى تقبله المؤسسة وهي واعية بما تقبله.

## 1.5 مبادئ لا تتغير

تتغير التقنيات كل بضع سنوات لكن مبادئ الحماية ثابتة منذ عقود، وأول هذه المبادئ الدفاع في العمق (Defense in Depth) الذي يقضي ألا نعتمد على طبقة حماية واحدة مهما كانت قوية، بل نبني طبقات متتابعة بحيث إذا سقطت واحدة صدت التي بعدها، فالقلعة لها خندق وسور وأبراج وحرس لا سور واحد فقط، وثانيها مبدأ الامتياز الأدنى (Least

1

(Privilege) الذي يقضي بالآلا يُمنح أي شخص أو نظام من الصلاحيات إلا ما يحتاج إليه لأداء عمله لا أكثر، لأن كل صلاحية زائدة هي باب إضافي للمهاجم حين يستولي على الحساب الذي يحملها.

وثالثها الفصل بين المهام (Segregation of Duties) الذي يمنع أن يكون الشخص الواحد قادراً على إتمام عملية حساسة من بدايتها إلى نهايتها وحده، فمن يُدخل أمر الدفع لا يعتمد، ومن يكتب البرنامج لا ينشره في بيئة الإنتاج، ورابعها افتراض الاختراق (Assume Breach) الذي يقضي بأن نصمم أنظمتنا على أساس أن المهاجم موجود في الداخل، فنراقب ونجزئ ونحد من الحركة بدل أن نطمئن إلى أن السور لم يُخترق بعد، ومن هذا المبدأ انبثق نموذج انعدام الثقة (Zero Trust) الذي نفصله في فصل الهوية.

وخامسها البساطة، لأن النظام المعقد يصعب فهمه وتأمينه ومراجعته، وكل تعقيد زائد يخفي ثغرة محتملة، وسادسها الأمن بالتصميم وبالإعداد الافتراضي (Secure by Design and by Default)، أي أن تُبنى الحماية في المنتج منذ لحظة تصميمه وأن تكون إعداداته الأولية آمنة دون أن يحتاج المستخدم إلى ضبطها، لأن الحماية التي تُضاف في النهاية تكون أضعف وأعلى، وسابعها أن الإنسان جزء من النظام، فأقوى تشفير في العالم لا يحمي كلمة مرور كتبها صاحبها على ورقة ملصقة بالشاشة، ولذلك خصصنا لهذا الجانب فصلاً كاملاً.

## 1.6 أنواع الضوابط

تُصنف الضوابط من زاويتين، فمن زاوية طبيعتها تنقسم إلى ضوابط إدارية (Administrative) كالسياسات والإجراءات والتدريب والعقود، وضوابط تقنية (Technical) كالجدران النارية والتشفير وأنظمة كشف

التسلل، وضوابط مادية (Physical) كالأبواب والكاميرات والحراسة والأقفال، ولا تكتمل حماية بغير الأنواع الثلاثة لأن الجدار الناري لا يمنع موظفاً من إدخال غريب إلى غرفة الخوادم، والسياسة المكتوبة لا تمنع هجوماً آلياً على الشبكة.

ومن زاوية وظيفتها تنقسم الضوابط إلى خمس وظائف، فالضابط الوقائي (Preventive) يمنع الحدث قبل وقوعه كالمصادقة متعددة العوامل، والضابط الكاشف (Detective) يكتشف الحدث حين يقع أو بعده كأنظمة المراقبة وسجلات التدقيق، والضابط التصحيحي (Corrective) يعالج أثر الحدث كاستعادة النسخ الاحتياطية، والضابط الرادع (Deterrent) يثني المهاجم عن المحاولة كلافقات التحذير والعقوبات المعلنة، والضابط التعويضي (Compensating) يحل محل ضابط أساسي تعذر تطبيقه كمراقبة مشددة لنظام قديم لا يمكن تحديثه.

### جدول 1.2 وظائف الضوابط الخمس

| الوظيفة | ماذا تفعل             | أمثلة                            |
|---------|-----------------------|----------------------------------|
| وقائي   | يمنع الحدث قبل وقوعه  | المصادقة متعددة العوامل والتشفير |
| كاشف    | يكتشف الحدث عند وقوعه | أنظمة كشف التسلل وسجلات التدقيق  |
| تصحيحي  | يعالج أثر الحدث       | استعادة النسخ الاحتياطية         |
| رادع    | يثني عن المحاولة      | التحذيرات والعقوبات المعلنة      |
| تعويضي  | يحل محل ضابط متعذر    | مراقبة مشددة لنظام قديم          |

## 1.7 لماذا تُخترق المؤسسات مع كل هذا

تكشف تحقيقات الحوادث عاماً بعد عام أن معظم الاختراقات لا تقع بسبب تقنيات هجوم متقدمة بل بسبب أخطاء معروفة، فثغرة لم تُرَقَّع مع أن تحديثها متاح منذ شهور، وحساب يحمل صلاحيات مدير بكلمة مرور تُستخدم في موقع آخر تسربت منه، وخدمة سحابية تُركت مفتوحة للجميع بإعداد خاطئ، وموظف ضغط على رابط في رسالة بدت كأنها من مديره، ومورد خارجي يملك صلاحية الوصول إلى الشبكة دون أن يعرف أحد ما يفعله بها، وغياب شبه كامل للرؤية بحيث يبقى المهاجم في الشبكة أسابيع قبل أن يلاحظه أحد.

والقاسم المشترك بين هذه الأسباب أنها ليست مشكلات تقنية صرفة بل مشكلات في الإدارة والثقافة والانضباط، فالمؤسسة التي تعرف أصولها وتصنفها وتحديث أنظمتها وتضبط صلاحياتها وتراقب شبكتها وتدريب موظفيها تصد الغالبية العظمى من الهجمات بأدوات متاحة للجميع، أما المؤسسة التي تشتري أعلى المنتجات دون هذه الأساسيات فهي تضع قفلاً ذهبياً على باب مفتوح.

## 1.8 الأمن عملية مستمرة لا منتج يُشتري

نختم هذا الفصل بالفكرة التي تحكم الكتاب كله، وهي أن أمن المعلومات ليس حالة تصل إليها المؤسسة ثم تستريح، بل عملية دائرة لا تتوقف لأن الأصول تتغير والتهديدات تتطور والثغرات تُكتشف كل يوم، ويلخص إطار الأمن السيبراني الصادر عن المعهد الوطني الأمريكي للمعايير والتقنية (NIST CSF) هذه العملية في وظائف متتابعة تبدأ بالحوكمة ثم تحديد الأصول والمخاطر ثم الحماية ثم الكشف ثم الاستجابة ثم التعافي، وتعود

الدائرة إلى بدايتها بما تعلته المؤسسة من كل جولة، وعلى هذا الترتيب تقريباً بُنيت أبواب الكتاب.

### ! أخطاء شائعة

- شراء المنتجات قبل جرد الأصول وتصنيفها، فتُحمى أشياء لا تهم ويُترك الأهم
- الخلط بين الأمن السيرياني وأمن المعلومات فتُهمل الوثائق الورقية والأحاديث والعنصر البشري
- الاعتماد على ضابط وقائي واحد كالجدار الناري دون كشف ولا تصحيح
- معاملة الخطر بوصفه شيئاً يزال بالكامل بدل أن يُخفّض إلى مستوى مقبول وموثق
- ترك قرار قبول الخطر لمدير تقنية المعلومات بدل مالك العملية

### ✓ قائمة تحقق

- ☐ قائمة أصول محدّثة بمالك لكل أصل
- ☐ تصنيف للمعلومات من ثلاثة إلى أربعة مستويات مطبق فعلاً
- ☐ لكل أصل حرج ضوابط وقائية وكاشفة وتصحيحية
- ☐ الخصائص الثلاث محددة الأولوية لكل نظام حرج
- ☐ مبدأ الامتياز الأدنى مطبق على الحسابات المميزة على الأقل
- ☐ الفصل بين المهام في العمليات المالية والنشر
- ☐ سجل بالمخاطر المتبقية المقبولة وموقع ممن قبلها
- ☐ دورة مراجعة منتظمة للضوابط لا مشروع ينتهي

## ☰ خلاصة الفصل

- المعلومات أصل له قيمة وتوجد في ثلاث حالات هي التخزين والنقل والاستخدام، وتتم بدورة حياة من الإنشاء إلى الإتلاف
- نمجي ثلاث خصائص هي السرية والسلامة والتوافر، وتضاف إليها الأصالة وعدم الإنكار والمساءلة والخصوصية
- أمن المعلومات مظلة أوسع من الأمن السيبراني، بينما تنظر حماية البيانات من زاوية الحقوق والقانون
- الخطر هو اجتماع تهديد وثغرة في أصل مع أثر، والضوابط تخفضه إلى خطر متبقي مقبول
- المبادئ الثابتة سبعة هي الدفاع في العمق والامتياز الأدنى والفصل بين المهام واقتراض الاختراق والبساطة والأمن بالتصميم وبالإعداد الاقتراضي، وأن الإنسان جزء من النظام
- الضوابط إدارية وتقنية ومادية بطبيعتها، ووقائية وكاشفة وتصحيحية وراعاة وتعويضية بوظيفتها

## 🔍 المصطلحات الأساسية

| المصطلح     | بالإنجليزية     |
|-------------|-----------------|
| السرية      | Confidentiality |
| السلامة     | Integrity       |
| التوافر     | Availability    |
| عدم الإنكار | Non-repudiation |
| الأصل       | Asset           |
| التهديد     | Threat          |
| الثغرة      | Vulnerability   |

| المصطلح         | بالإنجليزية      |
|-----------------|------------------|
| الخطر           | Risk             |
| الضابط          | Control          |
| الخطر المتبقي   | Residual Risk    |
| الدفاع في العمق | Defense in Depth |
| الامتياز الأدنى | Least Privilege  |

### ٨ خريطة إلى الأطر

يؤسس هذا الفصل للمفاهيم التي تقوم عليها كل الأطر، فالخصائص الثلاث هي تعريف أمن المعلومات في المعيار الدولي ISO/IEC 27000، ودورة الوظائف من الحوكمة إلى التعافي هي بنية إطار NIST CSF في إصداره الثاني، ومفردات الأصل والتهديد والثغرة والخطر هي لغة فصول إدارة المخاطر في الأطر الخليجية كلها.

### ٩ أسئلة للمراجعة

- 1 ما الفرق بين البيانات والمعلومات والمعرفة، وأيها نحمي؟
- 2 أي نظام تتقدم فيه السلامة على السرية، ولماذا اخترته؟
- 3 لماذا لا يكفي ضابط وقائي واحد مهما كانت قوته؟
- 4 ما الخطر المتبقي ومن يقرر قبوله؟
- 5 كيف تصنف الضوابط الآتية بحسب طبيعتها ووظيفتها: كاميرا المراقبة، وسياسة كلمات المرور، ونظام النسخ الاحتياطي، وتشفير القرص؟

## 6 لماذا يوصف أمن المعلومات بأنه عملية لا منتج؟

### تمارين تطبيقية

#### تمرين 1.1

اختر نظاماً تتعامل معه يومياً كتطبيق البنك أو بوابة الجامعة، وحدد لكل خاصية من الخصائص الثلاث مثلاً على انتهاكها وأثر ذلك فيك

#### تمرين 1.2

أعدّ قائمة بعشرة أصول في مؤسسة صغيرة تتخيلها وصنف كل أصل بحسب الخاصية التي يضر فقدانها أكثر

#### تمرين 1.3

صنف خمسة عشر ضابطاً تعرفها في جدول من بعدين هما الطبيعة والوظيفة ولاحظ الخانات الفارغة

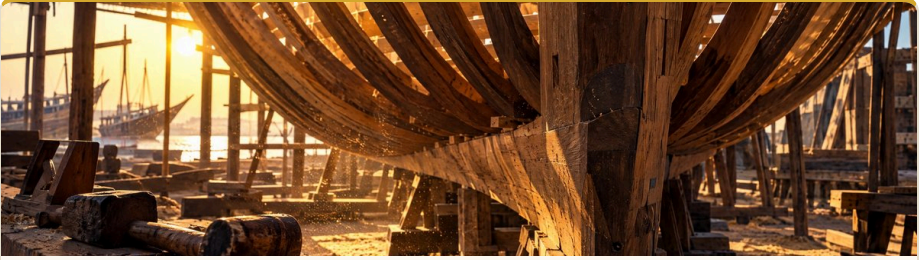
### للتعمق ومصادر الفصل

- ◆ المعيار الدولي ISO/IEC 27000 للمصطلحات والمفاهيم الأساسية
- ◆ إطار NIST CSF في إصداره الثاني ووثيقته التعريفية
- ◆ الضوابط الحرجة CIS Controls في إصدارها الثامن ودليل مجموعات التطبيق
- ◆ المسرد الرسمي للأمن السبراني الصادر عن الهيئة الوطنية للأمن السبراني في السعودية



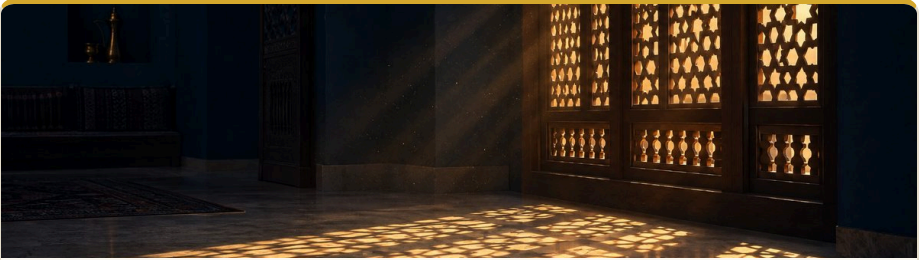
# ماذا ينتظرك في الكتاب

ثمانية عشر فصلاً آخر في أربعة أبواب نترج من الأسس إلى الآفاق.



## ١ الباب الأول: الأسس

- |                        |   |                                    |   |
|------------------------|---|------------------------------------|---|
| مدخل إلى أمن المعلومات | 1 | إدارة المخاطر                      | 3 |
| التحديات والمهاجمون    | 2 | الحوكمة والسياسات والأطر والامتثال | 4 |



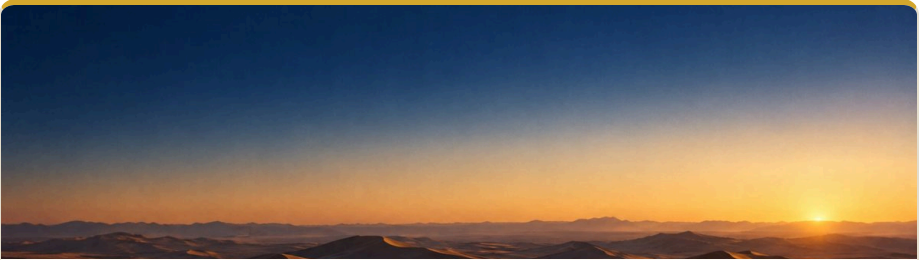
## ٢ الباب الثاني: الضوابط التقنية

- |                                   |   |                                      |    |
|-----------------------------------|---|--------------------------------------|----|
| التشفير                           | 5 | أمن الحوسبة السحابية                 | 10 |
| الهوية والمصادقة وإدارة الصلاحيات | 6 | أمن البيانات والخصوصية               | 11 |
| أمن الشبكات                       | 7 | أمن الأنظمة الصناعية وإنترنت الأشياء | 12 |
| أمن الأنظمة ونقاط النهاية         | 8 | المعمارية الأمنية                    | 13 |
| أمن التطبيقات والتطوير الآمن      | 9 |                                      |    |



### الباب الثالث: العمليات والصمود ٣

- |    |                                       |
|----|---------------------------------------|
| 14 | مراقبة الأمن والعمليات الأمنية        |
| 15 | الاستجابة للحوادث والتحقيق الرقمي     |
| 16 | استمرارية الأعمال والتعافي من الكوارث |
| 17 | العنصر البشري والتوعية الأمنية        |



### الباب الرابع: آفاق ٤

- |    |                                  |
|----|----------------------------------|
| 18 | الذكاء الاصطناعي وأمن المعلومات  |
| 19 | المسيرة المهنية في أمن المعلومات |

وفي الملاحق قائمة تحقق من أربعين ضابطاً للمؤسسة الصغيرة والمتوسطة، ومسرد يضم أكثر من مئتي مصطلح بالعربية والإنجليزية، والمراجع الدولية والمحلية.

- في كل فصل** أهداف التعلم أشكال ودراسات حالة أخطاء شائعة وقائمة تحقق خلاصة ومصطلحات خريطة إلى الأطر أسئلة وتمارين مصادر للتعمق



## أكمل القراءة

المرجع الخليجي الشامل في الأمن السيبراني

انتهى الفصل الأول، وبعده ثمانية عشر فصلاً في أربعة أبواب تُتدرج من الأسس إلى الآفاق، وفي الكتاب ثلاثة وعشرون شكلاً توضيحياً ومسردياً يضم أكثر من مئتي مصطلح وقائمة تحقق للمؤسسة الصغيرة والمتوسطة.

اشترِ الكتاب من أمازون

امسح الرمز لتفتح صفحة الكتاب

على أمازون من هاتفك

[amazon.com/dp/B0H6R5RR39](https://amazon.com/dp/B0H6R5RR39)



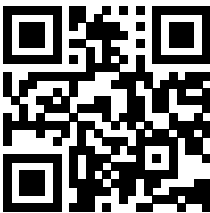
# من الخليج إلى الخليج

كتاب عربي شامل في أمن المعلومات والأمن السيبراني كُتب من الخليج إلى الخليج، يجمع الأساس النظري والممارسة العملية والسياق التنظيمي لدول مجلس التعاون في مرجع واحد يصلح للمقرر الجامعي ولبرامج التأهيل الحكومية وللممارس في الميدان.

تسعة عشر فصلاً في أربعة أبواب تتدرج من الأسس إلى الآفاق، يبدأ كل فصل بأهداف تعلم ويُختم بأخطاء شائعة وقائمة تحقق وخلاصة وجدول مصطلحات وخريطة إلى الأطر الدولية والخليجية وأسئلة وتمارين ومصادر، مع ثلاثة وعشرين شكلاً ودراسات حالة من واقع المنطقة، وملاحق فيها قائمة تحقق للمؤسسة الصغيرة ومسرد يضم أكثر من مئتي مصطلح.

يضع الكتاب إطار بنك الكويت المركزي الجديد والضوابط الأساسية السعودية ومعياري ضمان المعلومات في قطر وقوانين حماية البيانات في الدول الست في موضعها من كل فصل، ويرافقه موقع فيه فصل مجاني ومستودع مفتوح بالتدريبات والقوالب والأشكال.

علي العنزي مهندس وقيادي في أمن المعلومات، يقود أعمال هندسة الأمن في إحدى كبرى المؤسسات المالية في الكويت، ويرأس لجاناً لمخاطر الأمن السيبراني في القطاع المالي في الكويت والخليج، وهو عضو مجلس إدارة سابق في إحدى شركات تكنولوجيا المعلومات في الكويت.



الفصل الأول مجاناً  
والتدريبات والقوالب  
[gulfcyber.3li.info](http://gulfcyber.3li.info)

ISBN 9798178685440



9 798178 685440